

SIMATS ENGINEERING

ASSESSMENT TOOL 1

Name	Abinеш M
Register Number	192465050
Date	
Time	1 Hr

COURSE NAME: Cybersecurity Incident Handling And Response

COURSE CODE: CSA60

COURSE OUTCOME COVERED

CO3: *Assess incident identification processes using monitoring systems, log analysis, threat intelligence, detection mechanisms to verify incidents, classify threats, assess their impact. (BL2, BL3)*

Activity Tool : Log Analysis and Incident Identification (High)

Assessment Tool Weightage: 40%

Code of Conduct:

I Abinеш M 192465050 (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:

Abinеш M

192465050

RUBRICS FOR CALCULATION:

Criteria	Weightage	Level 4 (Exemplary)	Level 3 (Proficient)	Level 2 (Developing)	Level 1 (Beginning)
Log Analysis and Identification of Suspicious Activities	25%	Thoroughly analyzes relevant system, network, authentication, application, and security logs and accurately identifies suspicious activities and attack patterns.	Analyzes most relevant logs and identifies major suspicious activities with minor omissions.	Performs basic log analysis but misses important events or patterns.	Unable to analyze logs or identify relevant suspicious activities.
IOC Identification and Detection Sources	20%	Accurately identifies and validates relevant IOCs and effectively uses network, host, and application detection sources to support the investigation.	Identifies most relevant IOCs and detection sources with minor gaps.	Identifies limited IOCs or detection sources with insufficient analysis.	Unable to identify relevant IOCs or appropriate detection sources.
Event Correlation and Incident Verification	20%	Effectively correlates events from multiple sources and clearly verifies whether the activity represents a true incident or false positive using appropriate evidence.	Correctly correlates and verifies most events with minor omissions.	Provides limited correlation and incomplete incident verification.	Unable to correlate events or verify the incident.
Incident Classification, Prioritization, and Impact Assessment	20%	Accurately classifies and prioritizes the incident based on severity, asset criticality, affected users, data sensitivity, and business impact, with clear justification.	Correctly classifies and prioritizes the incident with reasonable impact assessment and minor gaps.	Provides basic classification and prioritization with limited impact analysis.	Unable to appropriately classify, prioritize, or assess the impact of the incident.
Documentation, Analysis, and Presentation	15%	Provides clear, professional documentation with logical analysis, evidence, incident timeline, conclusions, and appropriate diagrams or workflows.	Documentation is well organized and understandable with minor presentation or analytical issues.	Documentation is partially organized with limited evidence or analytical clarity.	Documentation is incomplete, poorly organized, and lacks supporting evidence or clear conclusions.

Security Log Analysis and Incident Identification

Question 1: Log Analysis and Incident Identification

An organization reporting repeated suspicious login attempts, unusual network traffic, and unexpected file changes is showing classic symptoms of an active or attempted compromise — potentially credential-based intrusion combined with lateral movement or data staging. As a security analyst, my approach follows a structured methodology: identify relevant log sources, apply analytical techniques to surface anomalies, correlate findings across sources, and map the results to known indicators of compromise (IOCs) and attacker tactics.

1. Types of Logs to Examine

- **Authentication and Identity Logs** — Windows Security Event Logs (Event IDs 4624, 4625, 4648, 4672), Linux `/var/log/auth.log` or `/var/log/secure`, VPN and SSO/IdP logs (Okta, Azure AD, Duo). These reveal who is logging in, from where, how often, and whether attempts are failing.
- **Network Logs** — Firewall and IDS/IPS logs (Snort, Suricata, Palo Alto, Cisco ASA), NetFlow/sFlow data, proxy and DNS logs, and packet captures where available. These expose unusual outbound connections, beaconing, port scans, and traffic to known-bad IP ranges or domains.
- **System and Endpoint Logs** — Windows Event Logs (System, Application), Sysmon logs (process creation, file, and registry events), Linux `syslog`, and EDR/antivirus alerts. These show process execution, privilege escalation, and service or scheduled-task creation.
- **File Integrity and Application Logs** — File Integrity Monitoring (FIM) tool output (Tripwire, OSSEC, Wazuh), web server and database logs, and configuration-management change logs. These pinpoint exactly which files were modified, created, or deleted, and by which process or user.
- **Centralized/SIEM Logs** — Aggregated and correlated events from a SIEM platform (Splunk, QRadar, Microsoft Sentinel, Elastic). This is the primary workspace for cross-source correlation and timeline reconstruction.

2. Analytical Approaches

- **Timeline reconstruction** — Aligning authentication events, network connections, and file-modification timestamps on a single timeline to see whether the sequence matches a plausible attack chain (e.g., failed logins → successful login → outbound connection → file change).
- **Baseline deviation / anomaly detection** — Comparing current login volume, source geography, traffic volume, and file-change frequency against a known-good baseline to flag statistically unusual behavior (impossible travel, off-hours access, atypical data volumes).
- **Pattern and frequency analysis** — Counting failed login attempts per account/source IP to detect brute-force or password-spraying patterns, and clustering repeated connection attempts to the same destination to detect beaconing.
- **Correlation across log sources** — Cross-referencing an account showing failed then successful logins with any subsequent network or file-system activity from the same session, host, or IP — a single log source rarely tells the full story.

- **Threat intelligence enrichment** — Checking source IPs, domains, and file hashes against threat-intel feeds and IOC databases to determine whether observed indicators match known malicious infrastructure or malware.
- **Log integrity verification** — Checking for gaps, cleared logs, or timestamp manipulation, since attackers commonly attempt to erase evidence — a missing log segment is itself a strong indicator.

3. Key Indicators to Look For

Category	Indicator	Why It Matters
Authentication	Multiple failed logins followed by success; logins from new geographies; impossible travel	Signals brute force or credential-stuffing success and possible account takeover
Network	Large outbound transfers, connections to rare/unknown destinations, beaconing at regular intervals	Consistent with data exfiltration or command-and-control (C2) communication
System/File	Unexpected changes to system binaries, config files, or scheduled tasks; new admin accounts	Indicates persistence mechanisms or tampering by an attacker with elevated access
Process	Unsigned or unusual processes, PowerShell/command-line obfuscation, LOLBins usage	Common technique for evading detection while executing malicious code

Taken together, a coherent narrative — for example, repeated failed logins on a service account, a successful login from an unfamiliar IP, followed by an outbound connection to a rare external host and a modified system file minutes later — would constitute strong evidence of an active security incident warranting escalation to containment and eradication.

Question 2: Analyzing User and System-Generated Report

This scenario combines a human-reported signal (an employee flagging a suspicious email) with a machine-generated signal (the monitoring system flagging unusual login activity) on the same user account. The analyst's task is to determine whether these two independent observations describe a single, connected incident — most plausibly a successful phishing attack that led to account compromise.

1. Analyzing the User-Generated Report

- Collect the reported email as an attachment or forwarded message (preserving original headers) rather than relying on a description, since headers contain the true sending infrastructure.
- Examine header fields — Return-Path, Received chain, SPF/DKIM/DMARC results — to check for spoofing or a sending domain that does not match the claimed sender.
- Assess the payload: inspect any links via a sandboxed URL analyzer and any attachments via a malware sandbox, without executing them directly on a production endpoint.
- Interview the reporting employee briefly: did they click the link, enter credentials, or open the attachment, and when did this occur? This establishes a possible compromise timestamp.
- Check whether other employees received the same or a similar message, indicating a broader phishing campaign rather than a targeted attempt.

2. Analyzing the System-Generated Report

- Pull the underlying authentication logs behind the alert: source IP address, geolocation, device fingerprint, user agent, and authentication method (password, MFA, token) used.
- Compare against the account's historical baseline — normal login hours, typical source locations/devices, and normal application usage — to quantify how anomalous this session is.
- Check for suspicious post-login activity, such as mailbox rule changes, unusual file/SharePoint access, mass downloads, or attempts to access systems outside the user's normal role.
- Determine whether Multi-Factor Authentication was satisfied, bypassed, or fatigued (repeated push prompts), which strongly affects the compromise assessment.

3. Correlating the Two Reports

The critical analytical step is aligning both reports on a shared timeline for the same user identity. If the anomalous login activity begins shortly after the timestamp the employee reports interacting with the suspicious email — and especially if the login originates from an IP or geography inconsistent with the user's normal pattern — this is strong evidence that the phishing email was the initial access vector and the account has been compromised.

- **Supporting correlation questions:**
 - Does the login IP resolve to infrastructure associated with the phishing email's sending domain or known malicious ranges?
 - Did the suspicious login use valid credentials (suggesting the user entered them on a phishing page) or exploit a different weakness?

- Is there evidence of session token theft (e.g., login without MFA prompt, or MFA satisfied via prompt bombing)?
- Has the compromised account subsequently been used to send phishing emails to other internal users (lateral phishing)?

4. Determining Whether an Incident Has Occurred

Based on this analysis, I would classify the situation using a simple decision framework:

- **Confirmed incident** — Timeline alignment, matching source infrastructure, and evidence of post-login misuse (mailbox rules, data access, lateral phishing) together indicate account compromise. This triggers formal incident response: password reset, session/token revocation, MFA re-enrollment, and a search for downstream impact.
- **Likely false positive** — The anomalous login is explained by a legitimate cause (VPN change, new device, travel) confirmed with the user, and the reported email is found to be benign (e.g., legitimate marketing or an internal test) after sandbox analysis. Documented and closed, with lessons applied to detection tuning.
- **Inconclusive / requires further monitoring** — Evidence is suggestive but not conclusive (e.g., unusual login with no clear link to the email). The account is placed under heightened monitoring, and complementary logs (endpoint, network) are pulled to gather additional evidence before final classification.

In all cases, the report and supporting evidence are documented in the incident tracking system, and — if compromise is confirmed — the phishing email's indicators (sender domain, URLs, attachment hashes) are distributed across the organization's email security and threat-intel tooling to block related follow-on attempts.

Conclusion

Both scenarios illustrate the same underlying principle of security analysis: no single log or report tells the full story in isolation. Effective incident identification depends on pulling together authentication, network, system, and application evidence into a coherent timeline, applying baseline and anomaly-detection techniques to separate genuine threats from noise, and correlating human-reported observations with machine-generated telemetry. A disciplined, evidence-based methodology — rather than reacting to any single alert — is what allows an analyst to confidently distinguish a real incident from a false positive and to respond proportionately.

- **Common best practices across both scenarios:**
 - Preserve original evidence (raw logs, email headers, packet captures) before analysis to maintain chain of custody.
 - Establish and maintain accurate behavioral baselines so anomalies are meaningful rather than guesswork.
 - Use a centralized SIEM or log-aggregation platform to make cross-source correlation practical at scale.
 - Document findings and decisions at every step, even when the conclusion is 'no incident,' to support audits and improve future detection.

- Feed confirmed indicators of compromise back into detection tooling to shorten response time for similar future activity.